

WP2 Multi-Sig Root-Key and Multi-Party Custody Policy

Version: draft v0.1.1 (not a production spec)

Date: 2026-08-13

Maps to: Charter v0.3.4 Article 19(4), Article 4, and Annex D

Status: A working start for engineering and security teams. Not formal law. Not a production spec.

Establish verifiable, auditable, single-point-resistant root-key governance so that production-sign rights, BMC / firmware-unlock rights, emergency-fuse rights, and recovery authorization cannot be captured by a single control plane — and so the policy docks completely with the capability-fuse state machine (WP3).

1. Purpose

Write Charter multi-party custody as an executable policy: root trust is verifiable, replaceable, and fusible. No single entity may hold the root alone or restore it alone.

2. Neutrality statement (must stand at the head of the document)

This policy does not name or presuppose any particular commercial entity, political team, state, or individual as the sole or permanent lawful operator of the world. Any organization may take part only under a public procedure, and only as a replaceable custodian. This policy forbids reading root-key governance as charter-level exclusive sovereignty for any named subject.

3. Core architectural principles

1. Use a public M-of-N multi-signature scheme.
2. Thresholds and member classes must be publicly verifiable (true identities may be partly masked within lawful privacy bounds; weights and role classes may not be hidden).
3. Signature weight controlled by the same corporate group, the same government, or the same interest alliance must not by itself reach the threshold that can unilaterally pass ordinary root operations. That cap must be written in public and recomputed on a fixed cycle.
4. Place physical custody nodes across multiple geographies / jurisdictions.
5. The root seed / root CA must be generated and sharded in a multi-witness offline cold-storage ceremony (or an equivalent high-assurance offline procedure). A single cloud account or a single software hot wallet is forbidden as root. Cold wallet / offline custody is the requirement; a hot wallet is the prohibited way to hold the root, not a recommendation.

4. Threshold tiers (mandatory)

Operation	Threshold	Notes
Day-to-day production signing	Lower M-of-N; still across at least two interest classes	Higher throughput allowed
BMC / firmware unlock	Mid-to-high M-of-N	Stage-0 hard condition
Emergency capability fuse	High threshold, or a pre-authorized conditional fuse policy	May trigger quickly
Recovery from a self-fused state	Highest threshold; must cross jurisdictions and interest classes	No automatic recovery

5. Hard replaceability (must be written into the policy)

- Every custodian must have a defined term.
- Removal conditions, succession rules, and emergency-replacement procedures must be defined in advance and published.
- An independent auditor periodically verifies substantive replaceability.
- No permanent vested interest or irrevocable status in any form.

6. Offline-ceremony minimum

- Root-seed generation must have multi-party physical presence (or equivalent high-assurance witness).
- After sharding, encrypt the shares and store them in cold storage (offline, not hot) in different jurisdictions / geographies.
- A complete ceremony-record abstract (the public portion) must be retained and auditable.
- No single subject may hold a complete backup that can restore the root alone.
- Restated: the root is not a hot wallet. A single software hot wallet, a single cloud KMS account, or a single online seed backup must not serve as root.

7. Mandatory dock to the capability fuse (WP3)

- When the frequency evaluator or safety monitor trips on a low-frequency / shadow control plane, the capability fuse must be able to engage.
- Recovery from LOCK / EVIDENCE to NORMAL has one lawful path: the highest-threshold multi-sig authorization defined by this policy.
- Any attempt to recover around multi-sig is itself a control-plane intrusion.

8. Stage application (aligned with the Charter)

- Stage 0: Newly deployed high-compute training / inference servers and their BMC / out-of-band management → production signing under Multi-Sig; BMC multi-sig unlock and audit are hard conditions.
- Stage 1: Edge high-compute and critical-infrastructure nodes → same as above, plus stronger asset ledgers and operational attribution.
- Stage 2: Broader device classes → advance by compliance marks and procurement gates; do not require an instantaneous global re-root of existing stock.

9. Required public artifacts

- ☐ This policy as a formal document
- ☐ Member role classes and weight rules (true identities may be partly masked)
- ☐ Publication channel for certificates and revocation lists
- ☐ Fuse-and-recovery runbook (consistent with the WP3 state machine)
- ☐ Stage 0 / 1 compliance-mark standard
- ☐ Replaceability-audit cycle and report template

10. Non-goals (explicitly out of scope)

- Do not establish any named global hardware sovereign
- Do not authorize replacing lawful national courts
- Do not set large-scale automatic physical destruction as the default remedy
- Do not require taking over all already-shipped chips without supply-chain negotiation

End. Maps to Charter v0.3.4. Mechanism-neutral. Do not weaken the hard constraints.